

תמצית השיעור הרביעי

30.11.25

קייס 1 – מושגים בסיסיים (מידע רגיש, מאגר, צמידות, רמת אבטחה)

1.1 מידע בעל רגישות מיוחדת

הקבוצה אמרה:

- מידע שמוגדר בחוק כ"ברגישות מיוחדת".
- כולל מידע משפחתי, מיני, גנטי, ביומטרי, רפואי, פיננסי וכו'.
- "מצריך רמת אבטחה בינונית ומעלה".

המרצה דייק:

- החוק מגדיר "מידע ברגישות מיוחדת" – "זה רוב מה שאנחנו חושבים עליו כמידע רגיש" (פיננסי, רפואי, גנטי, ביומטרי, עבר פלילי וכו').
- אבל רמת אבטחה בתקנות נשענת על הגדרה קצת אחרת של "מידע רגיש".
- יש חפיפה גדולה, אבל לא 100% – החוק עודכן, התקנות עדיין לא ולכן יש פער קטן.

לקח:

- להכיר:
 - חוק – מידע ברגישות מיוחדת.
 - תקנות אבטחת מידע – מידע רגיש להגדרת רמת אבטחה.
- לזכור: בינונית $\approx$ גבוהה (בפרקטיקה), לא "באמצע".

1.2 מאגר מידע

הקבוצה אמרה:

- מאגר מידע = פרטי מידע על אדם, המעובדים באמצעי דיגיטלי.
- לגבי מסמכים פיזיים: בדרך כלל נוצרו מתוך מידע דיגיטלי או נסרקו לדיגיטל, אז בפועל מכוסים.

המרצה דייק:

- אחרי תיקון החוק – ההגדרה מתמקדת בעיבוד באמצעי דיגיטלי.

לקח:

- מאגר = מידע אישי + עיבוד + אמצעי דיגיטלי.
- לא חייב "מספר מינימלי" של רשומות.

1.3 מאגר לדיוור ישיר

הקבוצה אמרה:

- אם המאגר משמש לדיוור ישיר:
 - צריך הסכמה.
 - צריך לציין שזה פרסומת.
 - לציין מספר מאגר.
 - לאפשר הסרה בקלות.

המרצה דייק:

- לא כל פרסומת = דיוור ישיר.
- אם שולחים הודעה אחידה לכל הלקוחות – לפעמים זה לא נחשב דיוור ישיר.
- אבל אם זה מאגר שייעודו **דיוור ישיר** – יש דרישות מיוחדות, כולל רמת אבטחה **בינונית**.

לקח:

- להבדיל:
 - פרסומת כללית ללקוחות
 - דיוור ישיר אישי מפולח (שם חובה הסכמה, סימון, אפשרות הסרה).

1.4 צמידות המטרה

הקבוצה אמרה:

- חובה:
 1. להגדיר מראש את מטרת איסוף המידע.
 2. אסור להשתמש במידע למטרה אחרת.

המרצה:

- אמר שזה **נוסח מצוין** – זה בדיוק עיקרון צמידות המטרה.

לקח:

- משפט לזכור:

"מידע שנאסף למטרה – X אסור להשתמש בו למטרה Y, אלא אם יש בסיס חוקי/הסכמה חדשה".

1.5 רמת אבטחה בינונית

הקבוצה אמרה:

- נדרשת כשמדובר ב:
 - מידע רגיש
 - דאטה ברוקר
 - גוף ציבורי (ממשלתי).

המרצה דייק:

- הגדרת רמת האבטחה (בסיסית/בינונית/גבוהה) נמצאת בתוספת לתקנות.
- "בינונית" בחוק = **קרובה לגבוהה**, לא "באמצע."
- תקנות מפרטות לכל דרישה אם היא חלה על כל מאגר / בינוני / גבוה (למשל: לוגים, מבדק חדירה וכו').
- ברמת אבטחה גבוהה – חלות חובות נוספות (למשל מבדק חדירה חובה, יותר בקרה).

לקח למבחן:

- בינונית = הרבה דרישות טכניות (לוגים, נהלים, בקרה).
- גבוהה = בינונית + עוד שכבה.
- להכיר שההגדרה בפועל באה מהתקנות, לא מהבטן.

1.6 מחזיק vs בעל שליטה בפועל (controller / processor)

הקבוצה (דרך הדוגמה):

- נתנו דוגמה:
 - מל"מ שכר – מחזיק של מאגר העובדים של רשות.
 - מבקרת פנים עם הרשאות צפייה בלבד – מחזיק.
- בעל שליטה = מי שמנהל באמת את המאגר.

המרצה דייק/חידד:

- מבחן טוב:

אם נבקש מגורם למחוק/להחזיר מידע – האם מותר לו לסרב?

- אם כן – הוא בעל שליטה. (controller)
- אם לא – הוא מחזיק. (processor)
- יש חריגים כמו רואי חשבון / גופי ביקורת – בחו"ל נתפסים כ"בעלי שליטה" עצמאיים (אצלנו החוק פחות ברור שם).

לקח:

- בעל שליטה: קובע מטרות ואמצעים, "שולט" בהחלטה.
- מחזיק: עובד עבור בעל השליטה, אבל עדיין חלות עליו חובות בתקנות.

קייס 2 – חברת "כסף של אחרים בע"מ" (חובת רישום / הודעה)

תיאור הקייס בקצרה:

- חברה ציבורית ("נסחרת בבורסה") אוספת מידע מאוז רגיש על כ-100,000 אנשים עשירים:
 - שמות, כתובות, מידע פיננסי, קשרים עסקיים/משפחתיים וכו'.
- משתמשת במידע לניתוח עבור עצמה – לא מוכרת את המידע.

הקבוצה אמרה:

- זה לא מאגר שנסחר במידע.
- זו לא רשות ממשלתית (לא "גוף ציבורי" לעניין התקנות).
- לכן: אין חובת רישום.

המרצה דייק:

- ההיגיון נכון:
 - **רישום מאגר** היום חובה רק אם:
 - סחר במידע (data broker)
 - או גוף ציבורי (ממשלתי).
- אבל:
 - בגלל שיש מידע רגיש + 100,000 נושאי מידע → רמת אבטחה גבוהה.
 - ויש חובת הודעה לרשות (לא רישום, אלא הודעה).

לקח:

- לשון:
 - **רישום מאגר** – רק סחר במידע או גוף ציבורי.
 - **הודעה לרשות + רמת אבטחה גבוהה** – כשיש הרבה נושאי מידע ו/או מידע רגיש).
- "חברה ציבורית" ≠ "גוף ציבורי".

קייס 3 – חברת שכר/הנה"ח ("אברהם ובניו")

תיאור הקייס:

- חברת הנהלת חשבונות ושכר.
- מחזיקה רשימות עובדים של לקוחותיה:
 - 50 לקוחות.
 - כ-350 עובדים לכל לקוח ← כ-17,500 עובדים.
- כולל מידע רגיש (שכר, תנאים וכו').
- שאלה: מה רמת האבטחה החלה?

הקבוצה אמרה (בדיון פנימי):

- בהתחלה חשבו – מאגר בינוני, אולי גבוה, כי יש הרבה עובדים ומידע רגיש.
- אחר כך חלק אמרו:
 - מאגר הלקוחות שלה = 50 חברות (מאגר בסיסי).
 - מאגר העובדים = בעצם שייך ללקוחות, לא לה.
- חלק טענו גם שצריך לספור רשומות (50×5000 וכו'), והייתה בלבול בין רשומות/אנשים.

המרצה דייק:

- חשוב להפריד:
 1. מאגר הלקוחות של חברת השכר עצמה (שלה - CRM)
 - מידע על אנשי קשר של הלקוחות ← בדרך כלל מאגר בסיסי.
 2. מאגר העובדים של כל לקוח –
 - בעל השליטה: הלקוח (החברה המעסיקה).
 - חברת השכר היא מחזיק בלבד.
- מחזיק לא קובע את רמת האבטחה של המאגר – הוא צריך לעמוד במה שהחוק דורש ולעתים גם בדרישות הלקוח.
- לפי התקנות: כל החובות על בעל שליטה חלים גם על המחזיק, כך שהוא לא יכול "לרדת" מתחת למינימום החוקי, גם אם הלקוח מזלזל.

לקח למבחן:

- תזכורת:
 - מאגר אחד CRM = של הספק – בסיסי.
 - מאגר שני = מאגר העובדים של הלקוח – בעל השליטה הוא הלקוח, הספק = מחזיק.
- מחזיק:
 - לא מגדיר רמת אבטחה עצמאית,
 - אבל חייב לפחות לעמוד במינימום החוקי, ובדרך כלל גם בדרישות הלקוח.

קייס 4 – חברת השכרת רכב שמעבירה מידע לסטארט-אפ

תיאור הקייס (באופן כללי):

- חברת השכרה מחזיקה מאגר לקוחות (מאגר רשום, כנראה לדיוור / שירות).
- מחליטה להעביר מידע לסטארט-אפ חיצוני לצורך מחקר / פיתוח מוצר, מעבר למה שהלקוח ציפה.
- שאלה: האם צריך להודיע ללקוחות? לבקש הסכמה? האם מותר בכלל?

הקבוצה אמרה:

- באופן "מחמיר":
 - זה שימוש חדש במידע ← אסור בלי הסכמה.
 - עצם המסירה לסטארט-אפ היא בעייתית – זה כבר "סחר/מסירת מידע".
 - לא מספיק לעדכן את מדיניות הפרטיות באתר.

המרצה דייק/הרחיב:

- מדובר בשינוי מטרה מהותי + מסירת מידע לצד שלישי שעושה שימוש עצמאי.
- ולכן:
 - לא מספיק לעדכן את האתר.
 - צריך יידוע אקטיבי של הלקוחות (מייל/סמס וכו').
 - ברוב המקרים – גם הסכמה (לפחות לסט שימוש חדש בזה).
- יש הנחיות של הרשות:
 - לשינוי מטרה מהותי ← נדרש יותר מאשר "עדכנו מדיניות באתר".
- הדגיש: עכשיו ממילא מעדכנים מדיניות בגלל תיקון 13 – זו הזדמנות ליישר קו, אבל זה לא פוטר מהחובה האמיתית.

לקח:

- שינוי מטרה משמעותי + צד שלישי עצמאי =
 - הפרת צמידות המטרה אם לא קיבלו הסכמה/יידוע.
- להיזהר ליפול לפח של "העלינו עדכון למדיניות וזהו".

קייס 5 – ניהול הרשאות (רשימת מורשי גישה)

תיאור הקייס (מרומז):

- בחברה מוציאים מדי פעם **פלט של הרשאות** (מי יש לו גישה למה).
- אין בהכרח נוהל קליטה/עזיבה/החלפת תפקיד מסודר.
- נשאל: האם עצם האפשרות להוציא פלט הרשאות מספיקה לעמידה בתקנות?

הקבוצה אמרה:

- לא מספיק.
- צריך:
 - נוהל קליטה/עזיבה מסודר.
 - נוהל עדכון הרשאות בעת החלפת תפקיד.
 - סקר תקופתי של הרשאות.

המרצה דייק:

- צודקים.
- כדי לעמוד בתקנות צריך:
 - **מדיניות + נוהל כתוב.**
 - **ניהול אקטיבי** של ההרשאות (לא רק דוח פעם ב-..).
 - סקר הרשאות = השוואה בין "איך צריך להיות" לבין "איך בפועל".
- עצם זה שהמערכת מסוגלת להוציא פלט – **לא שווה עמידה בתקנות.**

לקח:

- לשאלה על הרשאות – תמיד לחשוב על:
 - מדיניות, נוהל, תיעוד, סקירה תקופתית.
 - לא רק "יש לנו רשימה באקסל".

קייס 6 – פרצת אבטחה בחברת ("DataFlow") SAAS

תיאור הקייס:

- חברת SAAS עם כ-120 לקוחות.
- זיהוי פעילות חריגה בשרת ייצור.
- תוקף חיצוני הוריד קבצים עם מידע אישי של כ-4,500 משתמשים (שמות, מיילים, קבצים שהעלו).
- ה:CISO –
 - מנתק את השרת מהאינטרנט,
 - מדווח למנכ"ל וליועמ"ש,
 - **לא מדווח ל - DPO** עוד לא ברור אם זו הפרת פרטיות).
- ה DPO – מגלה במקרה אחרי 6 שעות.
- ה:CISO: אולי אין דלף בפועל.

- יועמ"ש: חושש מנזק תדמיתי, רוצה לחכות.
- מנכ"ל: למה ה DPO – לא בעניינים?
- DPO: אם הייתם מזמנים אותי בזמן – כבר היינו מתקדמים בהחלטה על דיווח לרשות/ללקוחות.

הקבוצה אמרה:

- ה DPO – חייב להיות מעורב מההתחלה בכל אירוע שיש בו אפשרות לדליפת מידע אישי.
- אחריות ה- DPO:
 - לעבוד עם ה- CISO להערכת חומרה.
 - לעבוד עם היועמ"ש על היבט משפטי/חובות דיווח.
 - לעבוד עם ההנהלה על מסרים (ללקוחות, תקשורת וכו').
- ה DPO – לא "אחראי ביצוע" טכני, אבל אחראי לוודא שמקיימים את החובות לפי החוק.

המרצה דייק/הרחיב:

- לפי החוק:
 - ממונה הגנת הפרטיות (DPO) הוא איש הקשר מול הרשות כברירת מחדל.
 - הרשות מצפה שהוא יהיה מעורב באירועי אבטחה הקשורים למידע אישי.
- יש חובה בחוק: **דיווח מיידי** לרשות על **אירוע אבטחה חמור**.
 - אי-דיווח בזמן – הפרה בפני עצמה.
- תפקיד ה DPO – בפועל:
 1. לוודא שיש **נוהל אירועי אבטחה** שבו הוא מוזכר.
 2. לוודא ש- CISO/הנהלה/יועמ"ש יודעים:
 - שצריך לעדכן אותו בכל חשש לדליפה.
 3. לבנות **תרבות ארגונית** שבה עובדים יודעים למי פונים.
- הערה צינית-אמיתית: לפעמים **בכוונה** מעכבים עדכון ה DPO – כדי "לא להפעיל" חובת דיווח – וזה לא תקין.

לקח:

- DPO =
 - ייעוץ + פיקוח + קשר לרשות + עזרה בניהול המשבר.
- באירוע אבטחה:
 - לערב את ה DPO – מיד כשיש חשש לדלף, לא אחרי "שנדע בוודאות".
- הרשות יכולה לקנוס רק על איחור בדיווח.

קייס 7 – יורי MongoDB, והכופר

תיאור הקייס:

- יורי – מתכנת בחברת הייטק, ובשעות הפנאי נותן שירותי QA לחברת אבטחת מידע "פצצה גרעינית".
- ב-1.5: פותח חשבון אחסון ב-MongoDB.
- ב-7.5: מעתיק את **יוזרים של הלקוח** (משתמשים) לשרת האחסון כדי לבצע אנליזה על הלוגים.
- משאיר את המחשב פתוח ורץ – הולך הביתה.
- כעבור שבוע: נכנס ל-MongoDB-ורואה:
 - כל המידע נמחק.
 - הודעת כופר: "המידע אצלנו, תשלם 1 ביטקוין או שנפרסם בדארקנט תוך 48 שעות."
- בחקירה פורנזית:
 - עשרות לוגים של **כניסה/קריאה/מחיקה** בדאטאבייס,
 - החל מתאריך 4.5, בהפרשים של מאיות השנייה (בוט).

שאלות:

1. האם זה אירוע אבטחה?
2. האם הוא "אירוע אבטחה חמור?"

הקבוצה אמרה:

- ברור שזה **אירוע אבטחה**.
- לגבי "חמור":
 - תלוי ברמת האבטחה של המאגר (בסיסי / בינוני / גבוה).
 - יש טענה שזה **שני אירועים**:
 1. הפריצה עצמה (מ-4.5).
 2. ההתנהלות של יורי (השארת מחשב פתוח).
- חלק אמרו:
 - אם רק נמחק מידע ולא יצא החוצה – אולי זה "רק" פגיעה בשלמות מידע, לא בפרטיות.
 - אחרים אמרו: יש קריאה ושימוש ← פגיעה בפרטיות.

המרצה דייק/הרחיב:

- לפני תיקון 13: אפשר היה לטעון שמחיקה בלבד, בלי יצוא מידע, פחות "פרטיות וקליינט".
- אחרי תיקון 13:
 - "שימוש במידע" מוגדר רחב – כולל גם **קריאה/מחיקה**.
 - כאן יש גם איום מפורש על פרסום בדארקנט ← **חשש ברור לדלף**.
- סיווג "אירוע חמור" תלוי:
 - ברמת האבטחה של המאגר (בינוני/גבוה).
 - בסוג המידע (רגיש/רגיל).
 - בהיקף ובפגיעה בפועל.

לקח:

- כל רנסומוור כזה עם:
 - גישה למידע אישי,
 - קריאה/מחיקה/איום פרסום ← **אירוע אבטחה**, ובדרך־כלל גם "חמור."
- לזכור:
 - "שימוש" = כל פעולה במידע, לא רק הפצה.
 - מחיקה בלבד – יכולה להיות אירוע אבטחה, אבל לא תמיד תסווג "חמור"; כשיש איום/שימוש ← כן.